Lab 13 — Linux Hardening Baseline with Lynis

You will audit a fresh Ubuntu host, score its hardening posture, apply CIS-aligned fixes, and re-score.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt): - `lynis` - `unattended-upgrades`

Step 1 — Install Lynis

```
apt update && apt install -y lynis unattended-upgrades
```

```
lynis --version
```

Step 2 — Initial audit

```
lynis audit system --quick 2>/dev/null | tee lynis-before.txt
```

```
grep -E "Hardening index|Warnings|Suggestions" lynis-before.txt
```

Note the **Hardening index** (typically 60–70/100 on a stock cloud VM).

Step 3 — Apply baseline fixes

3a. Disable unused network services

```
systemctl disable --now avahi-daemon 2>/dev/null
systemctl disable --now cups 2>/dev/null
```

3b. Set strict file permissions

```
chmod 600 /etc/ssh/sshd_config
chmod 644 /etc/passwd
chmod 600 /etc/shadow
```

3c. Enable automatic security updates

```
dpkg-reconfigure -f noninteractive unattended-upgrades
```

3d. Harden SSH

```
sed -i 's/^#*PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
```

```
sed -i 's/^#*PasswordAuthentication.*/PasswordAuthentication no/'
/etc/ssh/sshd_config
```

```
sed -i 's/^#*X11Forwarding.*/X11Forwarding no/' /etc/ssh/sshd_config
```

```
systemctl reload ssh
```

3e. Set login banner (directive control)

```
cat > /etc/issue.net <<'EOF'
```

```
WARNING: Authorised use only. All activity is logged.
```

```
EOF
```

```
sed -i 's|^#*Banner.*|Banner /etc/issue.net|' /etc/ssh/sshd_config
```

```
systemctl reload ssh
```

3f. Kernel hardening

```
cat >> /etc/sysctl.d/99-hardening.conf <<'EOF'
```

```
kernel.dmesg_restrict=1

kernel.kptr_restrict=2

net.ipv4.conf.all.rp_filter=1

net.ipv4.conf.all.accept_redirects=0

net.ipv4.icmp_echo_ignore_broadcasts=1

EOF

sysctl --system >/dev/null
```

Step 4 — Re-audit and compare

```
lynis audit system --quick 2>/dev/null | tee lynis-after.txt

grep "Hardening index" lynis-before.txt lynis-after.txt
```

Expect the score to climb 10–15 points.

Step 5 — Map remaining suggestions to CIS controls

```
grep -E "^Suggestion|^Warning" lynis-after.txt | head -10
```

Each Lynis ID can be cross-referenced to a CIS control (for example, `AUTH-9282 → CIS 5.4.1` for password expiry).

Free online tools

- **CIS Benchmarks (free PDFs)** — https://www.cisecurity.org/cis-benchmarks
- **OpenSCAP / scap-security-guide** — https://www.open-scap.org
- **DISA STIG library** — https://public.cyber.mil/stigs/
- **Lynis docs** — https://cisofy.com/documentation/lynis/
- **dev-sec.io Ansible/Chef hardening** — https://dev-sec.io

What you learned

- How a hardening score quantifies risk before vs. after changes.
- The high-impact, low-effort wins (SSH, sysctl, auto-updates).
- Where to look up authoritative baselines (CIS, STIG) for any platform.